

Security Audit & Hardening + pnpm Migration

Context

The founder (non-technical) asked for a comprehensive security audit, a check for dependency vulnerabilities, and a migration from npm to **pnpm** with verified, reliable packages. They asked the plan to fix the ****fundamental architectural and configurational**** issues, not just patch dependencies.

Audit verdict: the app is fundamentally well-built. The hard things are right:

- The Anthropic/OpenAI/Gemini keys and the Supabase **service-role key** live only in Edge Function secrets — never in the repo or browser ([supabase/functions/evaluate-writing/index.ts:13-22](#)).
- Only the **publishable/anon key** is committed ([src/lib/supabaseConfig.ts:13-14](#)), which is safe because every table has owner-only Row-Level Security ([supabase/migrations/0001_init.sql:22-103](#)); the global `ai_usage` table has **no** client policies at all.
- No `dangerouslySetInnerHTML`, `eval`, or unsanitized DOM injection found.
- The PWA service worker precaches only build assets — it does **not** cache authenticated API responses ([vite.config.ts:16-24](#)).
- The AI cost guard chain is solid: per-user daily limit + global monthly auto-shutoff + input-hash cache + LanguageTool-first to avoid LLM calls.

The remaining issues are configuration/architecture gaps. Decisions taken with the founder: **full hardening, code everything + leave a dashboard checklist** for founder-only steps, and ship **CSP in report-only mode first** (zero white-screen risk).

Findings & Fixes

A. Dependency vulnerabilities (npm audit: 2 moderate)

- **react-router / react-router-dom open redirect** (GHSA-2j2x-hqr9-3h42, <6.30.4). Current: 6.30.3. Fix: bump `react-router-dom` to ^6.30.4. No other vulns.
- 573 total deps; many are merely **outdated** (React 18→19, Tailwind 3→4, Vite 6→8) — **not security issues**. We will NOT do major-version upgrades in this pass (high regression risk, no security benefit). Only the security bump + safe patch bumps.

B. npm → pnpm migration (with verified-package guardrails)

- Add `"packageManager": "pnpm@<pinned>"` to `package.json`.
- Generate `pnpm-lock.yaml`; **delete** `package-lock.json`.
- Add `.npmrc/pnpm-workspace.yaml` config for reliability:
 - `minimum-release-age` (cooldown, e.g. 1440 min) so freshly-published (possibly compromised) versions aren't pulled immediately — defends against supply-chain attacks via hijacked package releases.
 - `verify-store-integrity=true` (default on; content-addressable store verifies each package's integrity hash).
 - Use `pnpm.overrides` in `package.json` to **force** the patched `react-router` transitive version across the whole tree.
- Update CI ([.github/workflows/pages.yml](#)): replace `cache: npm + npm ci` with

pnpm/action-setup (SHA-pinned) + cache: pnpm + pnpm install --frozen-lockfile
+ pnpm run build.

- Update CLAUDE.md Commands section (npm → pnpm) so future sessions use the right tool.

C. Content-Security-Policy — currently ABSENT (`index.html` has none)

- Add a CSP `**<meta http-equiv="Content-Security-Policy-Report-Only">**` tag first (founder verifies the live site loads cleanly; a follow-up flips it to enforcing).

GitHub Pages can't set HTTP headers, so a meta tag is the only mechanism.

- Policy (allowlist derived from actual usage):
 - `default-src 'self'`
 - `connect-src 'self' https://*.supabase.co https://api.languagetool.org` (Supabase REST/auth/functions + LanguageTool; LLM providers are called server-side only)
 - `style-src 'self' 'unsafe-inline' https://rsms.me` (Inter CSS; `unsafe-inline` needed for styled-in styles — removed once fonts are self-hosted, see E)
 - `font-src 'self' https://rsms.me`
 - `img-src 'self' data: · script-src 'self' · frame-ancestors 'none'`
 - `base-uri 'self' · form-action 'self' · object-src 'none'`

D. Edge Function CORS is wide-open (`Access-Control-Allow-Origin: \*`, index.ts:28)

- Any website can invoke the function with a forwarded token. Lock to an allowlist.
- **Fix:** replace the static `*` with an origin check against an allowlist

(`genauly.de`, `www.genauly.de`, `http://localhost:5173`, and the

`*.github.io` fallback), reflecting the request `Origin` only when it matches.

Make the list configurable via an `ALLOWED_ORIGINS` function env var with a safe hardcoded default. `verify_jwt = true` + `getUser()` already require a real user; this closes the cross-site invocation gap.

E. Third-party font from rsms.me — no SRI, privacy + supply-chain exposure

- `index.html:24-25` loads Inter CSS+fonts from `rsms.me`. A compromise there could inject CSS (data exfiltration via `background-image` URLs); it also leaks user IPs to a third party.
- **Fix:** self-host Inter via the `@fontsource/inter` package (imported in CSS). Removes the external dependency entirely, simplifies the CSP (drop `rsms.me` and `'unsafe-inline'` from `style-src` where possible), and improves load reliability.

F. AI abuse hardening (denial-of-wallet / shared-cap DoS)

- **Input size cap:** the function only checks a **minimum** (`text.length < 10`, `index.ts:279`). Add a **maximum** (~3,000 chars) to bound token cost per call and prevent a single user burning quota with huge payloads.
- **Per-user monthly cap:** today there is only a per-user **daily** limit + a single **global** monthly \$ cap. One abuser (or a bot farm of guest accounts) can exhaust the global cap and lock out **everyone**. Add a per-user monthly call ceiling so one account can't drain the shared budget.
- **Guest abuse:** anonymous sign-in auto-creates accounts that can call the AI. This is gated behind Turnstile CAPTCHA — a **dashboard** step (see checklist).

G. CI hardening (`github/workflows/pages.yml`)

- Permissions are already correctly minimal (`contents:read`, `pages:write`, `id-token:write`) — good.

- **Fix:** pin official actions to commit SHAs (currently floating @v4/@v5 tags) to remove the tag-hijack supply-chain risk. Add `pnpm/action-setup` SHA-pinned.

H. Data retention note (low severity)

- `writing_evaluations.text` stores user-submitted practice text indefinitely (RLS owner-only, so it's private). Not fixed in code now; documented as a future retention-policy decision in the status doc.

Files to change

File	Change
package.json	react-router-dom ^6.30.4; add packageManager, pnpm.overrides
package-lock.json	delete (replaced by pnpm-lock.yaml)
.npmrc (new)	minimum-release-age, integrity settings
.github/workflows/pages.yml	pnpm setup + frozen install; SHA-pin all actions
index.html	add CSP report-only meta; remove rsms.me <link>s
src/index.css (or main.tsx)	import "@fontsource/inter" (self-hosted font)
supabase/functions/evaluate-writing/index.ts	CORS allowlist; max input length; per-user monthly cap
CLAUDE.md	npm → pnpm in Commands
docs/SECURITY.md (new)	audit summary + founder dashboard checklist + retention note
docs/PROJECT_STATUS.md	session log + resume pointer

Founder dashboard checklist (documented in `docs/SECURITY.md`, only the founder can do)

1. **Enable Turnstile CAPTCHA** on auth: Supabase → Authentication → Settings → Bot & Abuse Protection → enable Turnstile (deters bot guest-account farming).
2. **Set the function's `ALLOWED\_ORIGINS` secret** (and optional `MAX_TEXT_LEN`, `USER_MONTHLY_LIMIT`): Edge Functions → evaluate-writing → Secrets.
3. **Redeploy `evaluate-writing`** via the dashboard code editor (sandbox can't reach `api.supabase.com`) — paste the updated `index.ts`.
4. (Optional) Add Resend SMTP to fix the email magic-link rate limit (pre-existing).

Verification

- `pnpm install` then `pnpm run build` must be green (tsc -b + vite build) — the primary gate before any push.
- `pnpm audit` shows **0** known vulnerabilities (was 2 moderate).
- Confirm `dist/index.html` contains the CSP **report-only** meta and **no** `rsms.me` references; confirm Inter loads from a self-hosted `dist/assets/*.woff2`.
- Grep the built `dist/` for accidental secret leakage (`service_role`, `sk-`, `ANTHROPIC`) → must be empty (only the publishable key may appear).
- Edge Function: static review of the CORS allowlist + input cap + per-user cap logic (live test happens after the founder redeploys, since the sandbox can't deploy it).

- **Founder verifies the live site loads** with CSP report-only active before a later PR flips CSP to enforcing.

Rollout

- Ship as small, reviewable squash-merged PRs on [claude/todo-inventory-BUHq0](#) (realign to [origin/main](#) after each merge, per CLAUDE.md):
 1. **PR 1 — pnpm migration + dependency security fix** (build-system change, isolated).
 2. **PR 2 — Edge Function hardening** (CORS allowlist, input cap, per-user cap) + [docs/SECURITY.md](#) with the founder checklist.
 3. **PR 3 — Frontend hardening** (CSP report-only, self-hosted fonts).
 4. **PR 4 — CI SHA-pinning** + [docs/PROJECT_STATUS.md](#) update.
- A **future** PR (after founder confirms the live site is clean) flips CSP from report-only to enforcing.